



DOCUMENTO 35

REPORTE DE SEGURIDAD OWASP

Evaluación estática basada en OWASP Top 10 2021

Campo	Información
Proyecto	Toys Nova - Tienda virtual de juguetes
Código del documento	NS-QA-35
Versión	1.0
Fecha	5 de agosto de 2026
Elaboró	Edson Quintana - Vanessa Garcia Arzate QA (Analista e Infraestructura)
Revisión / aprobación	QA / Líder Técnico / Product Owner
Estado	Borrador controlado para revisión y firma

Limitación: esta evaluación es una revisión estática y de diseño sobre los archivos entregados. No es un pentest de producción, no valida HTTPS público y no demuestra explotación fuera del ambiente académico. Se usa OWASP Top 10 2021 como marco explícito.

1. Resumen ejecutivo

La aplicación aplica controles positivos como consultas preparadas, password_hash/password_verify y escape de salida en varias zonas. Sin embargo, existen riesgos críticos en recuperación de contraseña, autorización de roles, modificación de stock y checkout confiado al cliente. El sistema no debe considerarse listo para producción hasta corregir los hallazgos críticos y altos.



<https://github.com/GuadalupeSolisRuiz/Tienda-de-juguetes>



novasoft@gmail.com



123-456-7890



2. Evaluación OWASP Top 10

Categoría OWASP	Riesgo	Evidencia principal	Tratamiento prioritario
A01 Broken Access Control	Crítico	Editor puede enviar cambios de rol; stock sin autenticación; ausencia de CSRF.	Control server-side por rol, deny-by-default, CSRF y pruebas de autorización.
A02 Cryptographic Failures	Medio	Hash de contraseñas correcto; no hay evidencia de HTTPS; credenciales DB en código.	HTTPS, cookies seguras, secretos en variables de entorno.
A03 Injection	Alto	SQL usa prepared statements; cart.js/carrito.js insertan datos en innerHTML.	Escapar/validar salida y usar DOM seguro; pruebas XSS e inyección.
A04 Insecure Design	Crítico	Código de recuperación expuesto; checkout solo en cliente; stock reservado sin pedido.	Rediseñar recuperación, carrito y compra con transacciones server-side.
A05 Security Misconfiguration	Alto	root sin contraseña, directorios 0777, sin CSP/SRI, límites de upload no evidentes.	Hardening de servidor, mínimos privilegios y cabeceras.
A06 Vulnerable Components	Medio	CDN sin integridad; no hay inventario/lock claro de dependencias.	Fijar versiones, SRI, inventario y análisis de dependencias.
A07 Identification/Auth Failures	Crítico	Sin rate limit, sin regeneración visible de sesión, token sin expiración.	Rate limiting, session_regenerate_id, expiración y MFA opcional.
A08 Software/Data Integrity	Alto	Precio, cupones y carrito se calculan en cliente; no existe checkout transaccional.	Recalcular y validar en servidor; firmar/versionar artefactos.
A09 Logging/Monitoring Failures	Alto	No se observan logs de login, roles, recuperación, stock o compras.	Auditoría estructurada, alertas y retención.
A10 SSRF	No observado	No se identificaron funciones que soliciten URLs proporcionadas por usuario.	Mantener restricción; validar allowlist si se agregan integraciones.

3. Controles positivos observados

Control	Evidencia
Hash de contraseñas	registro_process.php y update_profile.php usan password_hash con BCRYPT.
Verificación de contraseñas	login_process.php y delete_account.php usan password_verify.
Consultas preparadas	Autenticación, perfiles, usuarios, productos y stock usan prepare/bind_param en gran parte del flujo.
Validación de correo	filter_var con FILTER_VALIDATE_EMAIL en registro, login y perfil.
Autorización parcial	gestion.php limita entrada a administrador/editor; admin_user_management.php exige administrador.
Escape parcial de salida	navbar.php usa htmlspecialchars para datos de sesión.

4. Hallazgos prioritarios

ID	Hallazgo	Impacto	Prioridad
SEC-01	El token de recuperación se revela en la respuesta.	Toma de cuenta sin acceso al correo.	Inmediata
SEC-02	Editor puede intentar elevar roles mediante POST.	Escalación de privilegios.	Inmediata
SEC-03	Stock modificable sin autenticación y con cantidades negativas.	Fraude, agotamiento o aumento artificial.	Inmediata
SEC-04	Checkout no valida precios ni persiste pedido en servidor.	Compra falsa y pérdida de integridad.	Inmediata
SEC-05	No hay protección CSRF visible.	Acciones forzadas con sesión activa.	Alta
SEC-06	Carrito usa innerHTML con datos controlables.	DOM XSS.	Alta
SEC-07	Sin rate limit, expiración robusta o regeneración de sesión.	Ataques de fuerza bruta/fijación.	Alta
SEC-08	Credenciales DB root/blank y permisos 0777.	Compromiso de servidor/datos.	Alta
SEC-09	Sin logs de seguridad y negocio.	Detección y respuesta insuficientes.	Alta



<https://github.com/GuadalupeSolisRuiz/Tienda-de-juguetes>



novasoft@gmail.com



123-456-7890



5. Plan de remediación

Plazo	Acciones
0-48 horas	Ocultar token; deshabilitar recuperación insegura; proteger stock y roles; bloquear checkout simulado si se presenta como real.
1 semana	Implementar CSRF, rate limiting, regeneración de sesión, validaciones de cantidad/precio, checkout transaccional y logs.
2-4 semanas	Hardening de servidor, secretos, HTTPS, CSP/SRI, límites de uploads, pruebas automatizadas y cobertura.
Antes de producción	Pentest controlado, revisión de dependencias, respaldo/restauración, monitoreo y aceptación formal.

6. Requisitos mínimos de re-prueba

- Reejecutar CP-015 a CP-020, CP-024, CP-035 a CP-046, CP-053, CP-054, CP-056 y CP-058.
- Confirmar que un usuario no autorizado recibe 401/403 y que no cambia ningún dato.
- Validar tokens de recuperación con expiración, un solo uso y envío externo.
- Comprobar que precios, descuentos, stock y pedidos se calculan en el servidor.
- Revisar logs, cookies Secure/HttpOnly/SameSite y cabeceras CSP/HSTS en staging.

7. Conclusión de seguridad

Dictamen: riesgo actual Alto/Crítico. Apto únicamente para demostración académica local y controlada, sin datos reales ni pagos, mientras permanezcan abiertos los hallazgos críticos. No apto para producción.

Fuentes internas utilizadas: Requisitos.pdf; HistoriasDeUsuario.docx; Manual de Usuario Toys Nova v1.0; tienda_virtual.sql; código fuente del repositorio GuadalupeSolisRuiz/Tienda-de-juguetes (rama main); Lista de documentos a entregar; Hoja membretada NovaSoft.

Firmas de validación

QA
Nombre, firma y fecha

Líder Técnico
Nombre, firma y fecha

Product Owner
Nombre, firma y fecha